Information Security CSC232

LECTURE-1 09-SEPT-2026

SAAD MALIK

Contents:

- Information Security and Its Importance
- Data vs. Information
- Information as an Organizational Asset
- Information Systems, Computer Security, Cybersecurity, and Information Security
- Key Security Concepts:

  Asset, Threat, Vulnerability, Attack, Exploit, Risk, Security Control

Opening Scenario

Sequential Label and Supply (SLS) - A Case Study

"For Amy, the day began like any other at the Sequential Label and Supply Company (SLS) help desk..."

What happened?

- Computers started behaving strangely
- Email system went down
- Multiple calls from users with similar problems
- Server room issues
- No dial tone on phones
- **Question:** What do you think caused this incident?

Opening Scenario - Discussion

What Went Wrong at SLS?

Possible Causes:

- Virus or worm infection
- Malicious software attack
- Network compromise
- Employee mistake
- System failure

Key Observation:

"It did not occur to her that a malicious software program, like a worm or virus, might be the agent of the company's current ills."

Lesson: Understanding information security is essential for everyone in an organization!

What is Information Security?

Information Security Defined

Definition

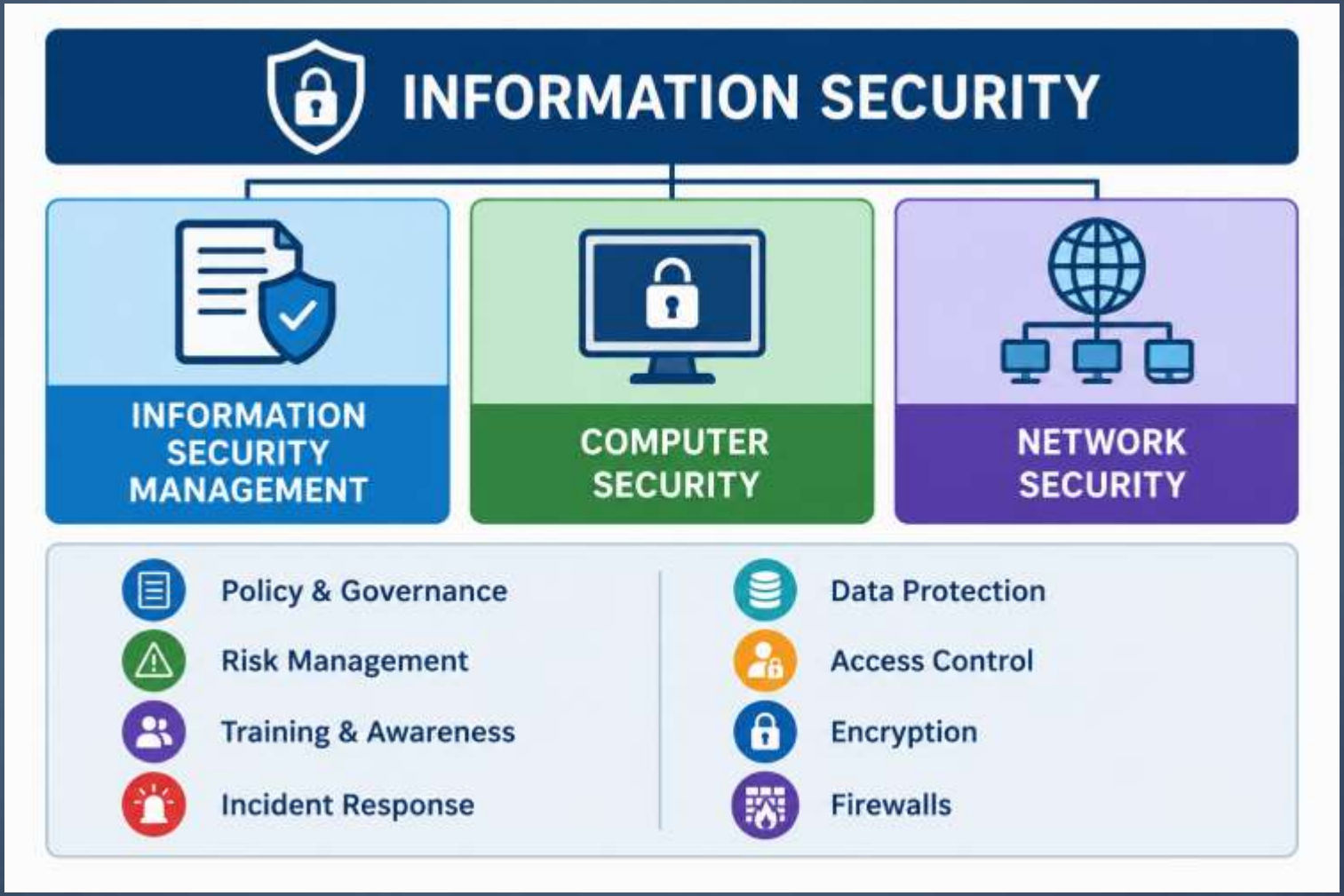
"Information security in an enterprise is a 'well-informed sense of assurance that the information risks and controls are in balance."'
— James Anderson

Key Points:

- It's about balancing security and access
- It's a management problem, not just a technical one
- It protects information assets
- It involves policy, education, training, awareness, and technology

Components of Information Security

The Information Security Framework



Why is Information Security Important?

The Importance of Information Security

Four Key Functions:

1. Protecting the Organization's Ability to Function

- Ensuring business continuity
- Preventing disruptions

2. Enabling Safe Operation of Applications

- Secure email, instant messaging, databases
- Protecting critical business applications

3. Protecting Data Collected and Used

- Customer data, financial records, intellectual property
- Data at rest and in motion

4. Safeguarding Technology Assets

- Hardware, software, networks
- Infrastructure protection

The Business Need for Security

Why Organizations Need Information Security

Business Perspective:

Information technology is essential for modern business

Without security, organizations face:

- Financial losses
- Reputation damage
- Legal liability
- Loss of customer trust
- Competitive disadvantage

Management Responsibility:

"Information security has more to do with management than with technology."
— **Charles Cresson Wood**

Data vs. Information

Understanding the Difference

Data

Raw, unprocessed facts and figures

No context or meaning

Examples:

- 42
- 3.14
- Ali
- 2024-01-15

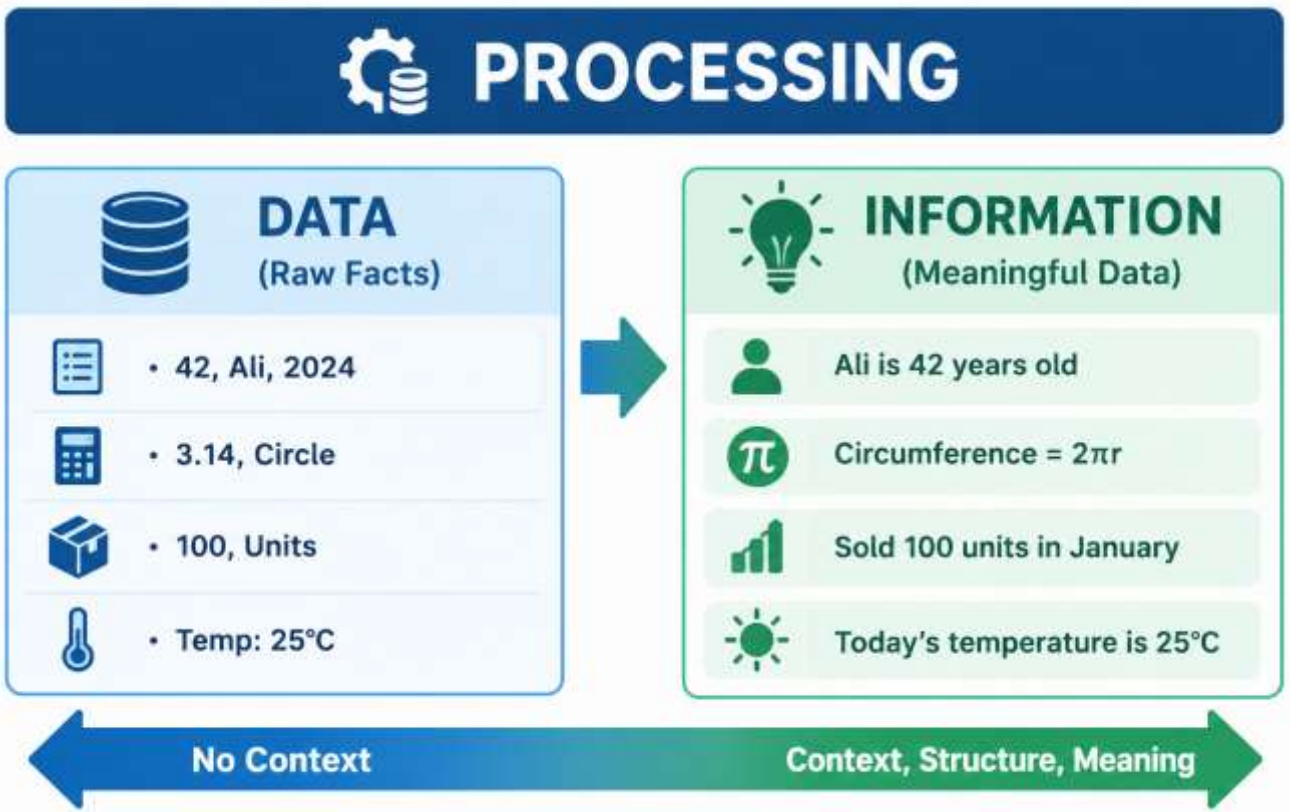
Information

Data that has been **processed, organized, and given context**

Has **meaning** and **value**

Examples:

- Ali's age is 42
- Value of Pi is 3.14
- Ali was born on January 15, 2024



Data vs. Information - Illustrated

Information as an Organizational Asset

Information is a Critical Asset

Why Information is Valuable:

1. Revenue Generation

- Customer data drives sales
- Market intelligence

2. Competitive Advantage

- Trade secrets
- Proprietary knowledge

3. Operational Efficiency

- Process data
- Decision support

4. Legal Compliance

- Financial records
- Employee data

Information Asset Categories:

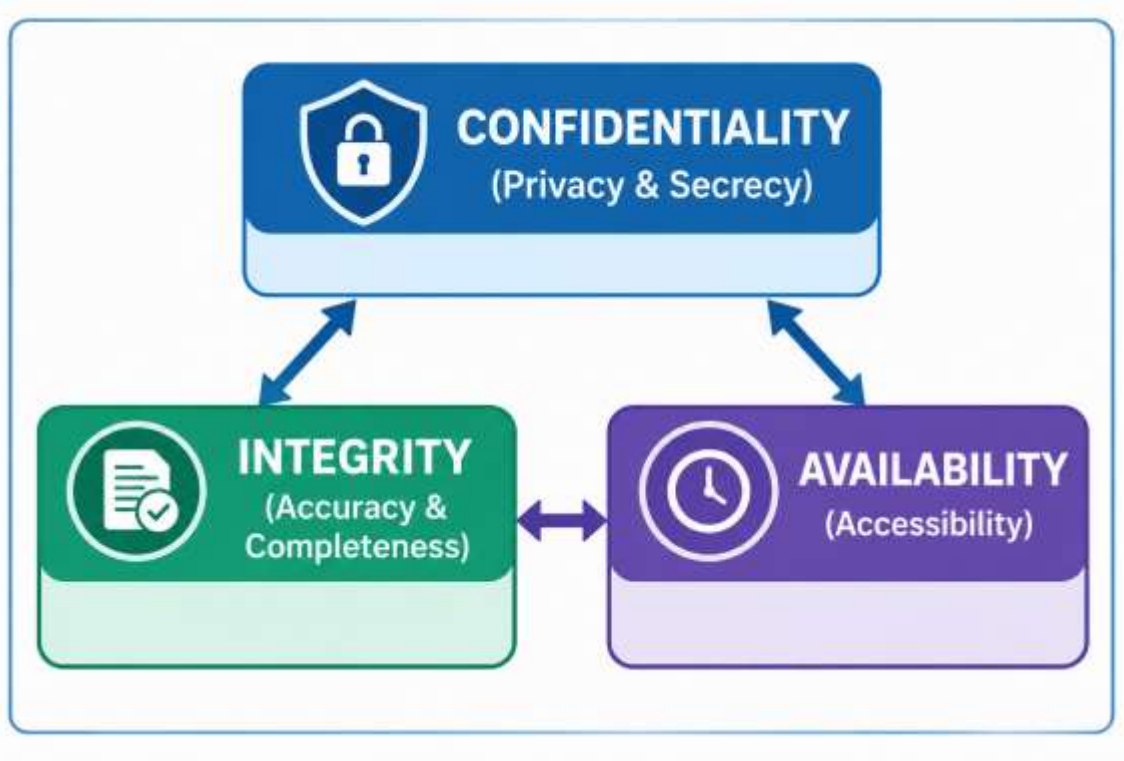
Confidential (strictly controlled)

Internal (company use only)

Public (released to public)

Information as an Asset - Characteristics

- Critical Characteristics of Information
- The C.I.A. Triad
- Confidentiality
- Integrity
- Availability
- Non-Repudiation
- AAA (Authentication, Authorization, Accounting)



The Foundation: the CIA triad

The three core goals of security that we are hired to protect.

- **Confidentiality:** Protecting data from unauthorized access.

  Example: Encrypting a hard drive.
- **Integrity:** Ensuring data is accurate and untampered with.

  Example: Using file hashes to verify a download wasn't altered.
- **Availability:** Ensuring systems and data are accessible to authorized users when needed.

  Example: Defending against a Denial-of-Service (DoS) attack.

Every attack we simulate aims to compromise one or more of these principles.

The Foundation: the CIA triad

1. Authentication (The "Who")

Definition: The process of verifying the identity of a user, device, or system. Proving you are who you say you are.

The Three Factors (Very important to mention):

Something you KNOW: Password, PIN, security question.

Something you HAVE: Smart card, phone (OTP), hardware token.

Something you ARE: Fingerprint, retina scan, voice recognition.

2. Authorization (The "What")

Definition: Determining what an authenticated user is **allowed** to do. (Access rights and permissions).

Crucial Distinction: You must be *authenticated* first, but *authorization* defines the scope.

3. Accounting (The "What did they do")

Definition: Tracking and recording the actions of a user once they are authenticated and authorized. This provides traceability.

4. Non-Repudiation (The "Can't Deny it")

Definition: Ensuring that a user or entity **cannot deny** (repudiate) having performed a specific action. It provides proof of origin and integrity.

How it works: Usually enforced through **Digital Signatures** (which you will cover in Week 7/8) and detailed **Logging**.

Critical Information Characteristics

Expanded Characteristics of Information

1. Availability

Authorized users can access information when needed

Example: Bank customers accessing their accounts online

Threat: Denial-of-service attacks, system failures

2. Accuracy

Free from errors and mistakes

Example: Correct bank balance

Threat: Data entry errors, corruption

3. Authenticity

Genuine and original, not fabricated

Example: Email from a real sender (not spoofed)

Threat: Email spoofing, identity theft

Critical Information Characteristics

4. Confidentiality

Protected from unauthorized disclosure

Example: Medical records, financial data

Threat: Hacking, eavesdropping, data breaches

5. Integrity

Whole, complete, and uncorrupted

Example: File hasn't been altered

Threat: Viruses, worms, unauthorized modification

6. Utility

Has value for a purpose

Example: Census data for policy makers

7. Possession

Ownership and control

Example: Encrypted data that is stolen but unreadable

Example - Information Characteristics

Real-World Examples

Scenario: Online Banking

- **Availability:** Can I check my balance anytime?
- **Accuracy:** Is my balance correct?
- **Authenticity:** Is this really my bank's website?
- **Confidentiality:** Can anyone see my transactions?
- **Integrity:** Has anyone changed my balance?
- **Utility:** Can I use this data to pay bills?
- **Possession:** Who has my financial data?

The ChoicePoint Breach (2005)

- 145,000 people had personal information stolen
- Identity thieves used fraudulent accounts
- **Violations:** Confidentiality, Possession

Information Systems

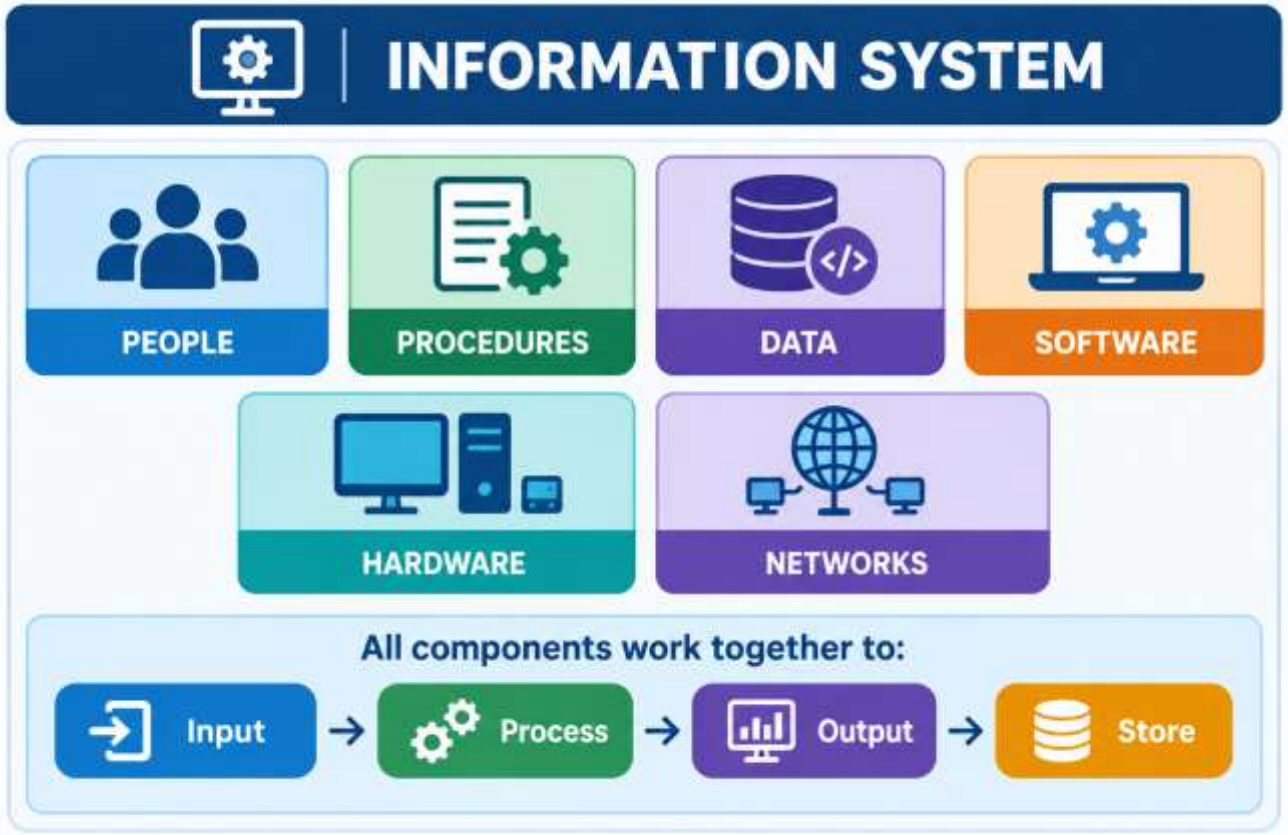
What is an Information System (IS)?

Definition:

"An information system is much more than computer hardware; it is the entire set of software, hardware, data, people, procedures, and networks that make possible the use of information resources in the organization."

The Six Components:

1. **Software** - Applications, OS, utilities
2. **Hardware** - Physical technology
3. **Data** - Stored, processed, transmitted
4. **People** - Users, administrators
5. **Procedures** - Instructions and policies
6. **Networks** - Communication infrastructure



Components of an Information System

Computer Security

Historical Context

Computer Security

"The need to secure physical locations, hardware, and software from threats."

Evolution:

- **1940s-1960s:** Physical security only
  - Mainframes in secure rooms
  - Physical access control
  - Simple document classification
- **1970s:** Operating system security
  - MULTICS (first secure OS)
  - Password protection
  - Access control
- **1980s:** Network security emerges
  - Personal computers
  - Networked systems
  - Growing threats

Cybersecurity vs. Information Security

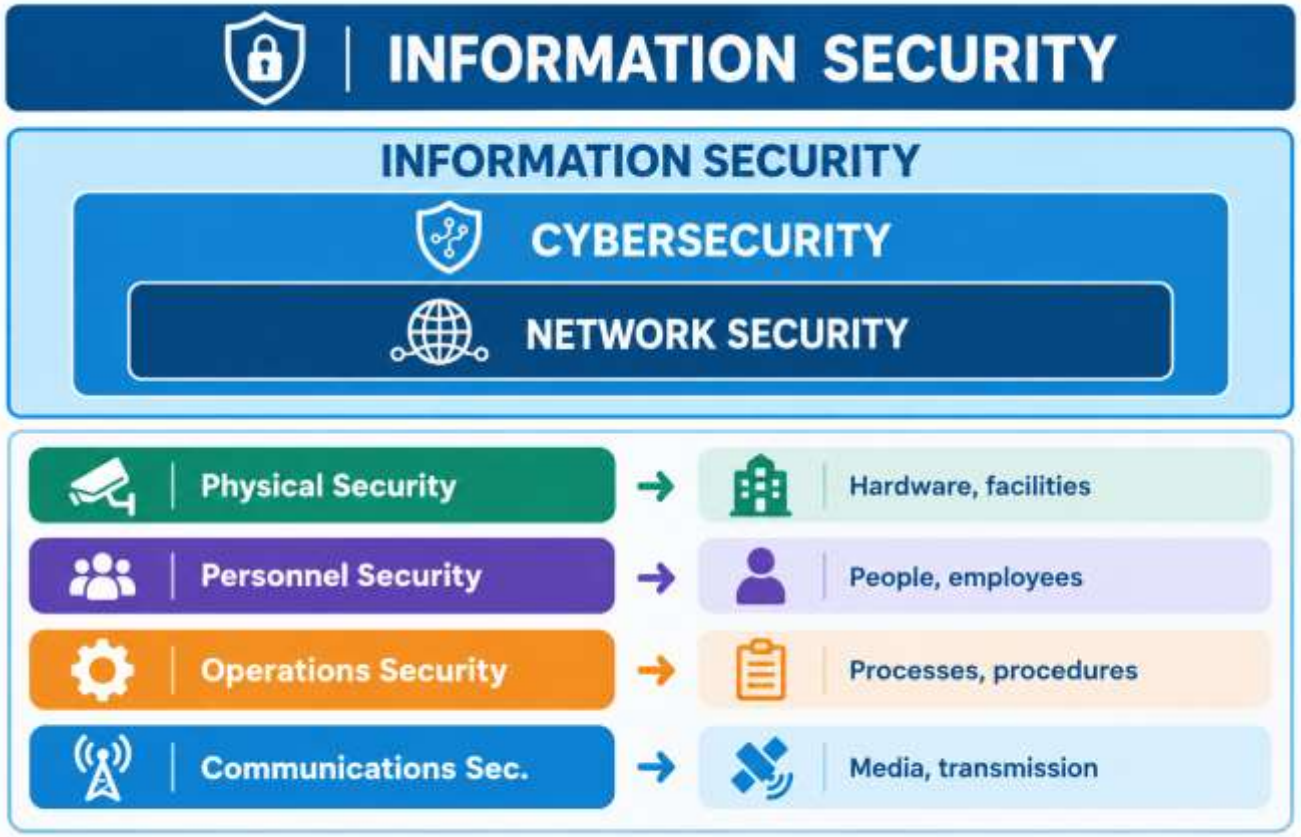
Understanding the Difference

Cybersecurity

- Focuses on **digital** environments
- Protects networks, computers, and data from **cyber attacks**
- Deals with threats from **the Internet**
- Examples:
  - Firewalls, intrusion detection
  - Anti-malware software
  - Network security

Information Security

- Broader scope - protects **all** information assets
- Includes **physical, digital, and paper** information
- Involves **people, processes, and technology**
- Examples:
  - Access control (physical and logical)
  - Data classification
  - Security awareness training



Comparing Security Domains

KEY POINT: CYBERSECURITY IS A SUBSET OF INFORMATION SECURITY!

Key Security Concepts

The Security Vocabulary

Essential Terms:

1. **Asset** - What we're protecting
2. **Threat** - Who/what can cause harm
3. **Vulnerability** - Weakness that can be exploited
4. **Attack** - Action that exploits a vulnerability
5. **Exploit** - Technique used to compromise a system
6. **Risk** - Probability of loss
7. **Security Control** - Measures to protect assets

Remember: These concepts work together!

Asset

What is an Asset?

"The organizational resource that is being protected."

Types of Assets:

Type	Examples
Logical	Web sites, information, data, databases
Physical	People, computers, servers, buildings
Intangible	Reputation, brand value, intellectual property

Asset Value:

- The value of an asset determines how much we should spend to protect it
- "Don't spend $100 to protect something worth $5"

Threat

What is a Threat?

"A category of objects, persons, or other entities that presents a danger to an asset."

Types of Threats:

Category	Examples
Human	Hackers, employees, terrorists
Natural	Fires, floods, earthquakes
Technical	Hardware failures, software bugs
Environmental	Power outages, temperature extremes

Threat Agent:

The specific instance of a threat

- **Example:** "Hackers" (threat) vs. "Kevin Mitnick" (threat agent)

Threat Examples

Real-World Threats

1. Human Threats

- **Hackers:** Kevin Mitnick, Mafiaboy
- **Insiders:** Disgruntled employees
- **Social Engineers:** Phishing, pretexting

2. Natural Threats

- **Fire:** Structural fires, electrical fires
- **Flood:** Water damage to systems
- **Earthquake:** Infrastructure damage
- **Lightning:** Power surges

3. Technical Threats

- **Malware:** Viruses, worms, Trojan horses
- **Hardware Failure:** Disk crashes
- **Software Bugs:** Buffer overflows
- **Obsolescence:** Outdated systems

Vulnerability

What is a Vulnerability?

Definition:

"*A weakness or fault in a system or protection mechanism that opens it to attack or damage.*"

Examples:

- **Software:** Unpatched operating system
- **Hardware:** Unlocked server room door
- **Network:** Open wireless access point
- **Human:** Employee who shares passwords
- **Procedural:** No backup system

Known vs. Unknown:

- **Known:** Documented and published vulnerabilities
- **Unknown (Zero-day):** Not yet discovered or patched

Vulnerability Examples

Common Vulnerabilities

Scenario: An Organization's Network

- **Vulnerability 1:** Unpatched web server software
- **Vulnerability 2:** Weak password policy
- **Vulnerability 3:** Unsecured wireless network
- **Vulnerability 4:** Employees clicking on phishing emails
- **Vulnerability 5:** No firewall between departments

Real-World Example:

Heartbleed (2014)

- Vulnerability in OpenSSL (used by millions of websites)
- Allowed attackers to read memory contents
- Exposed passwords, credit card numbers, private keys
- Required immediate patching of affected systems

Attack

What is an Attack?

Definition:

"An act that takes advantage of a vulnerability to compromise a controlled system."

Attack Types:

Type	Description	Example
Active	Attacker directly attempts to break in	Hacking, malware
Passive	Attacker monitors without interaction	Eavesdropping
Intentional	Deliberate harmful action	DDoS attack
Unintentional	Accidental damage	Employee mistake
Direct	Attacker uses own systems	Password cracking
Indirect	Uses compromised systems	Botnet attack

Attack Examples

Real-World Attacks

1. Denial-of-Service (DoS)

Overwhelms system with requests

Makes services unavailable

Example: Mafiaboy attack on Amazon, CNN, eBay (2000)

2. Malware Attack

Viruses, worms, Trojan horses

Destroys or steals data

Example: Nimda worm (2001) - spread globally in 25 minutes

3. Social Engineering

Manipulates people for information

Example: Phishing emails, pretexting

4. Password Attack

Brute force, dictionary attacks

Cracks user credentials

Example: Password file theft

Attack Vector

Definition

An **attack vector** is the **path, method, or means** by which an attacker gains unauthorized access to a system, network, or asset in order to deliver an exploit or malicious payload.

Simple Formula

text

Threat Agent → Attack Vector → Vulnerability → Exploit → Asset → Impact

Key Points

- It is **how** the attack reaches the target.
- It is not the same as the **exploit** — the exploit is the technique or code that takes advantage of a vulnerability.
- It is not the same as the **vulnerability** — the vulnerability is the weakness being exploited.
- Attack vectors can be **technical, human, or physical**.
- The sum of all possible attack vectors is called the **attack surface**.
- If you block the **attack vector**, the attack may never reach the vulnerability.

Common Attack Vectors

Types of Attack Vectors

1. Technical Vectors

- Email attachments
- Malicious websites / drive-by downloads
- Open network ports and services
- Misconfigured firewalls
- Remote access / VPN weaknesses
- USB devices
- Supply chain / third-party software

2. Human Vectors

- Phishing / spear phishing
- Social engineering
- Pretexting
- Shoulder surfing
- Tailgating
- Insider threat

3. Physical Vectors

- Unlocked doors
- Stolen laptops or hard drives
- USB drop attacks
- Dumpster diving
- Unsecured wiring closets

Attack Vectors from the Book

Attack Replication Vectors

The textbook identifies six common vectors used by malicious code such as worms:

Example:
The **Nimda worm (2001)** used five of these six vectors to spread across the Internet in less than 25 minutes.

Vector	Description
IP scan and attack	Infected system scans IP addresses and targets known vulnerabilities
Web browsing	Infected system makes Web content files infectious; users who browse become infected
Virus	Infected machine infects executable or script files on writable systems
Unprotected shares	Uses file system weaknesses to copy malicious code to reachable locations
Mass mail	Sends infected emails to addresses found in the address book
SNMP	Uses default SNMP passwords to gain control of network devices

Exploit

A piece of code, software, or technique that deliberately takes advantage of a vulnerability to cause unintended behavior in a system. E.g. A hacker uses a known "exploit" to attack a server that hasn't been patched for a specific software bug.

Key Points:

- Can be a **verb** (attacker exploits a system)
- Can be a **noun** (a documented exploit code)
- Exploits are often **shared** by hackers
- **Protection:** Keep systems patched and updated

Type	Description	Example
Software Exploit	Uses program bugs	Buffer overflow
Hardware Exploit	Uses physical weaknesses	Cold boot attack
Human Exploit	Uses social engineering	Phishing

Exploit Examples

Famous Exploits

1. Morris Worm (1988)

- Self-propagating program
- Took advantage of sendmail flaws
- Infected thousands of computers
- Cost ~$200 per site

2. SQL Injection

- Exploits poor input validation
- Attackers can access database data
- Example: Entering "OR 1=1" into a login form

3. Buffer Overflow

- Exploits memory management bugs
- Can execute arbitrary code
- Example: Sending more data than a buffer can handle

4. The PC Week Hack (1999)

- Expert hacker used CGI script exploit
- Defaced the site in less than 24 hours
- Never compromised the root OS

Risk

The potential for loss or damage when a threat exploits a vulnerability.

RISK = Threat × Vulnerability × Impact

RISK = Likelihood x Impact

Key Points:

- Risk is **always present**
- Can never be 100% eliminated
- Goal is to **reduce** risk to acceptable levels
- Risk is about **probability and impact**

Security Control

Also Known As:

- Safeguard
- Countermeasure

Types of Controls:

classification by **control function or purpose**

- **Preventive:** Firewalls, strong passwords, employee training.
- **Detective:** Intrusion Detection Systems (IDS), security cameras, log monitoring.
- **Corrective:** Backups

classification by **control nature or implementation method**

- Technical Controls
- Administrative Controls
- Physical Controls

Risk Example

Practical Risk Assessment

Scenario: Web Server Security

- **Asset:** E-commerce web server generating $1M/month
- **Threat:** Hackers
- **Vulnerability:** Unpatched server software

Risk Calculation:

- Likelihood of successful attack: 30%
- Potential damage: $50,000
- **Risk = 0.30 × $50,000 = $15,000**

Control Decision:

- Cost of firewall solution: $5,000
- Cost of damage: $50,000
- **Decision:** Implement the firewall (cost-effective)

Lesson: We invest in security controls when they are cheaper than potential losses.

Example — Phishing Attack Vector

Scenario

An employee receives an email that looks like it is from the bank.

- THREAT AGENT: Cyber criminal
- ATTACK VECTOR: Phishing email with malicious link
- VULNERABILITY: Employee not trained / unpatched browser
- EXPLOIT: Fake login page + credential stealer
- ASSET: Employee credentials / company bank account
- IMPACT: Financial loss, data breach, reputation damage

Controls That Block the Vector

- Email filtering
- Security awareness training
- Multi-factor authentication
- Browser patching
- URL reputation checking

The same attack can be stopped at multiple points. Blocking the vector is often the cheapest and most effective control.

The CNSS Security Model (The McCumber Cube)

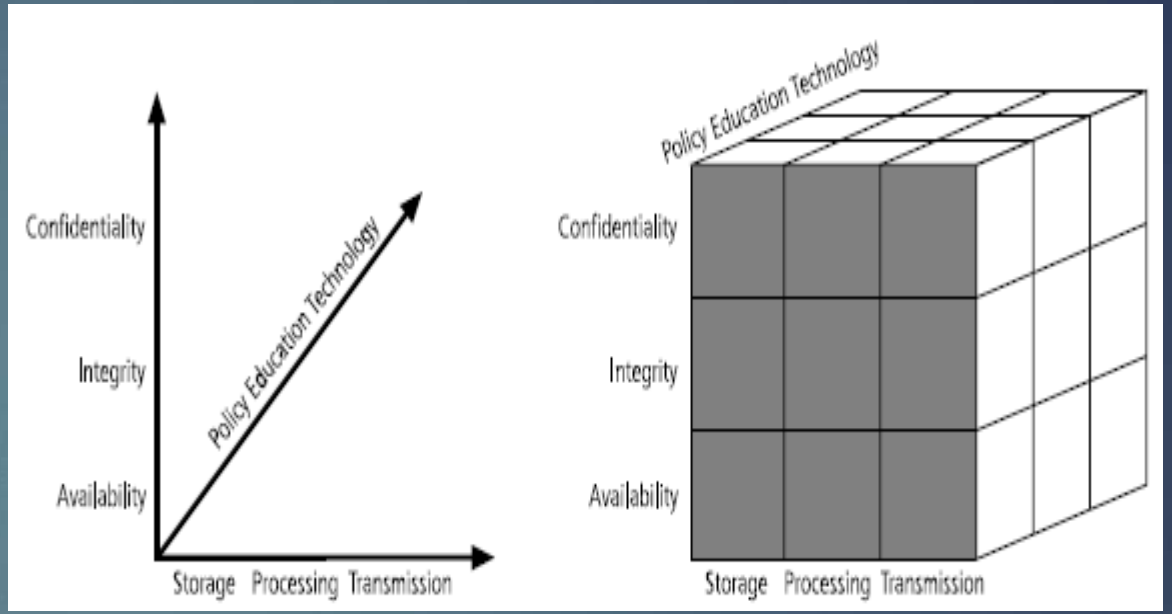
Information Security Model

Three Dimensions:

- **Information States**
  - Storage, Transmission, Processing
- **Security Objectives**
  - Confidentiality, Integrity, Availability
- **Security Countermeasures**

  Policy, Education & Training, Technology

3 x 3 x 3 = 27 cells



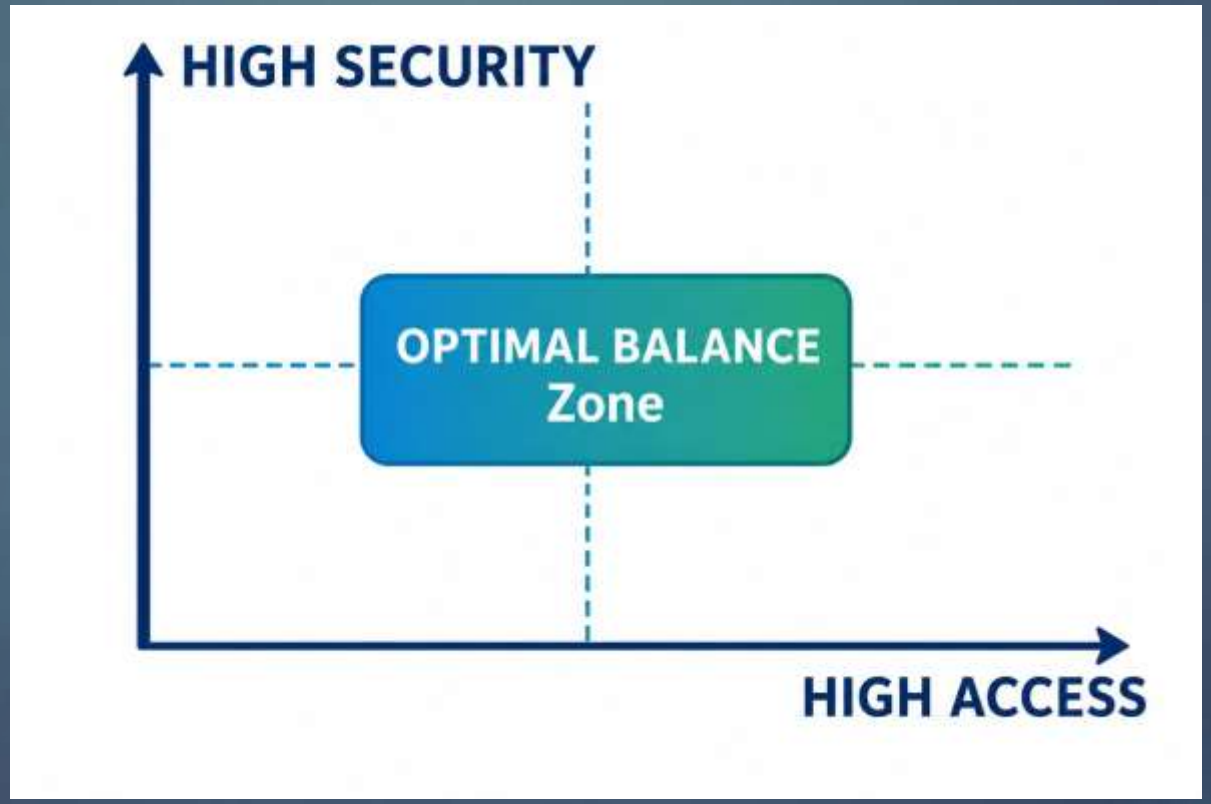
Balancing Security and Access

The Security Trade-off

The Dilemma:

- Too much security → Difficult to work
- Too little security → Vulnerable to attacks

Finding the Balance:



Summary

1. **Information security** is essential for protecting organizational assets
2. **Information** = Processed data with meaning
3. **Information systems** = People, procedures, data, software, hardware, networks
4. **Security concepts** work together:
   - **Assets** need protection from **threats**
   - **Vulnerabilities** can be exploited in **attacks**
   - **Risk** is the probability of loss
   - **Controls** reduce risk to acceptable levels

Thank you